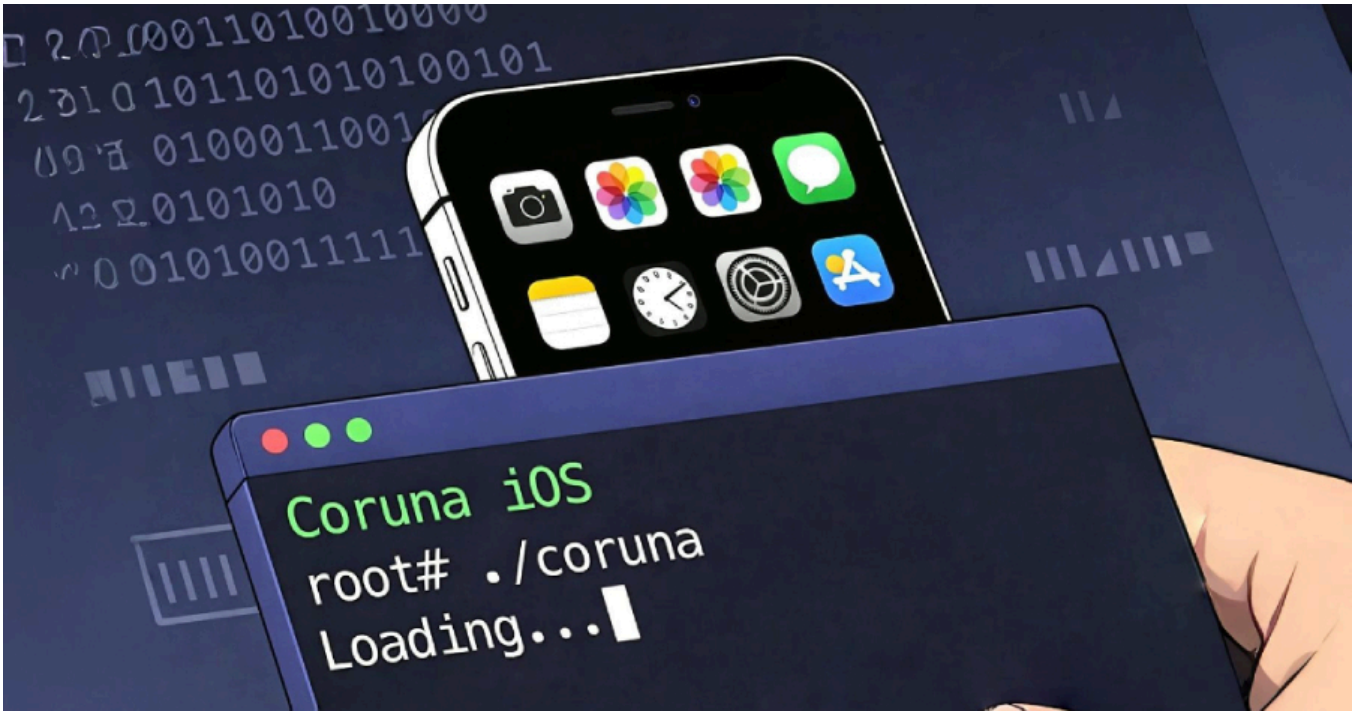
Coruna iOS Exploit Kit Uses 23 Exploits Across Five Chains Targeting iOS 13–17.2.1

thehackernews.com/2026/03/coruna-ios-exploit-kit-uses-23-exploits.html

The Hacker News March 4, 2026



Google said it identified a "new and powerful" exploit kit dubbed **Coruna** (aka CryptoWaters) targeting Apple iPhone models running iOS versions between 13.0 and 17.2.1.

The exploit kit featured five full iOS exploit chains and a total of 23 exploits, Google Threat Intelligence Group (GTIG) said. It's not effective against the latest version of iOS. The findings were first reported by WIRED.

"The core technical value of this exploit kit lies in its comprehensive collection of iOS exploits, with the most advanced ones using non-public exploitation techniques and mitigation bypasses," according to GTIG. "The framework surrounding the exploit kit is extremely well engineered; the exploit pieces are all connected naturally and combined together using common utility and exploitation frameworks."

The kit is said to have circulated among multiple threat actors since February 2025, moving from a commercial surveillance operation to a government-backed attacker, and finally, to a financially motivated threat actor operating from China by December.

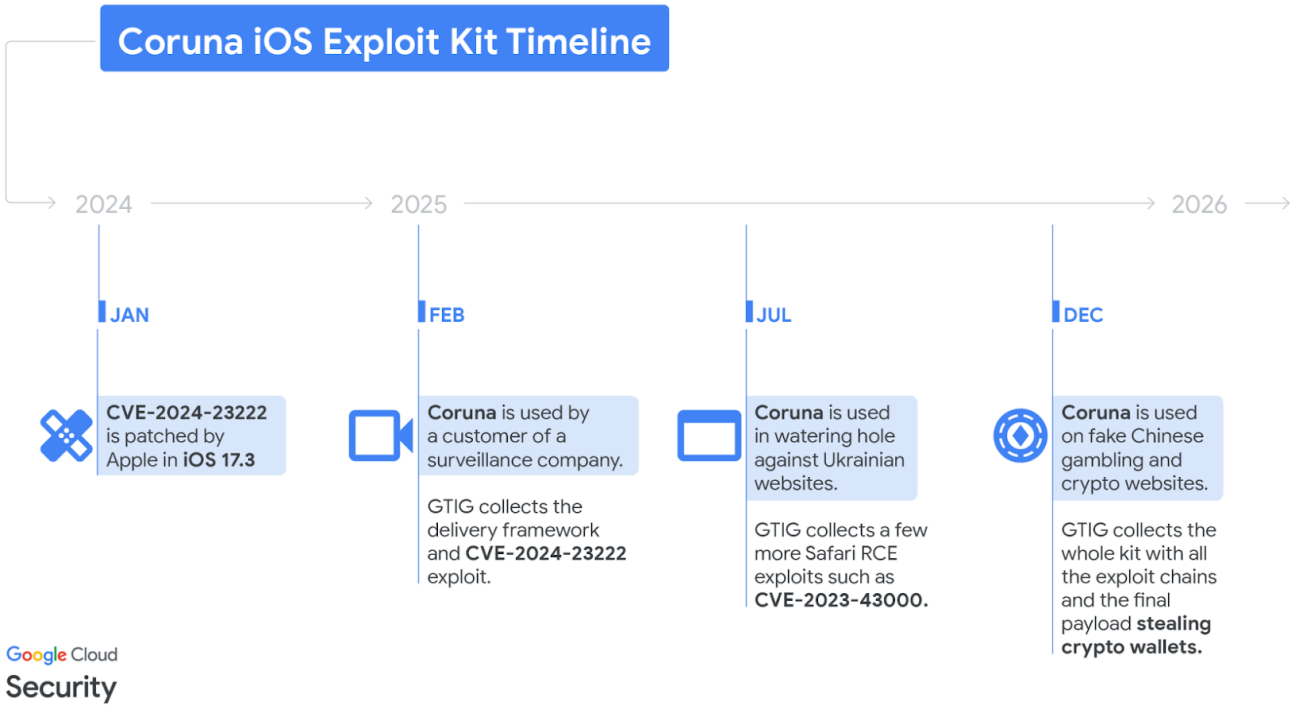
It's currently not known how the exploit kit changed hands, but the findings point to an active market for second-hand zero-day exploits, allowing other threat actors to reuse them for their own objectives. In a related report, iVerify said the exploit kit has similarities to previous frameworks developed by threat actors affiliated with the U.S. government.

"Coruna is one of the most significant examples we've observed of sophisticated spyware-grade capabilities proliferating from commercial surveillance vendors into the hands of nation-state actors and ultimately mass-scale criminal operations," iVerify said.

The mobile security vendor said the use of the sophisticated exploit framework marks the first observed mass exploitation against iOS devices, indicating that spyware attacks are shifting from being highly targeted to broad deployment.

Google said it first captured parts of an iOS exploit chain used by a customer of an unnamed surveillance company early last year, with the exploits integrated into a never-before-seen JavaScript framework. The framework is designed to fingerprint the device to determine if it's real and gather details, including the specific iPhone model and iOS software version it is running.

The framework then loads the appropriate WebKit remote code execution (RCE) exploit based on the fingerprint data, followed by executing a pointer authentication code (PAC) bypass. The exploit in question relates to CVE-2024-23222, a type confusion bug in WebKit that was patched by Apple in January 2024 with iOS 17.3 and iPadOS 17.3 and iOS 16.7.5 and iPadOS 16.7.5.



Fast forward to July 2025, the same JavaScript framework was detected on the domain "cdn.uacounter[.]com," which was loaded as a hidden iFrame on compromised Ukrainian websites. This included websites catering to industrial equipment, retail tools, local services, and e-commerce. A suspected Russian espionage group named UNC6353 is assessed to be behind the campaign.

What's interesting about the activity was that the framework was delivered only to certain iPhone users from a specific geolocation. The exploits deployed as part of the framework consisted of CVE-2024-23222, CVE-2022-48503, and CVE-2023-43000, the last of which is a use-after-free flaw in WebKit.

It's worth noting that CVE-2023-43000 was addressed by Apple in iOS 16.6 and iPadOS 16.6, released in July 2023. However, the security release notes were updated to include an entry for the vulnerability only on November 11, 2025.

The third time the JavaScript framework was detected in the wild was in December 2025. A cluster of fake Chinese websites, most of them related to finance, were found to drop the iOS exploit kit after instructing users to visit them from an iPhone or iPad for a better user experience. The activity is attributed to a threat cluster tracked as UNC6691.

Once these websites are accessed via an iOS device, a hidden iFrame is injected to deliver the Coruna exploit kit containing CVE-2024-23222. The exploit delivery, in this case, was not constrained by any geolocation criteria.

Further analysis of the threat actor's infrastructure led to the discovery of a debug version of the exploit kit, along with various samples covering five full iOS exploit chains. A total of 23 exploits spanning versions from iOS 13 to iOS 17.2.1 have been identified.

Some of the CVEs exploited by the kit and the corresponding iOS versions they targeted are listed below -

- Neutron - CVE-2020-27932 (versions 13.x)
- Dynamo - CVE-2020-27950 (versions 13.x)
- buffout - CVE-2021-30952 (versions 13 → 15.1.1)
- jacurutu - CVE-2022-48503 (versions 15.2 → 15.5)
- IronLoader - CVE-2023-32409 (versions 16.0 → 16.3.116.4.0)
- Photon - CVE-2023-32434 (versions 14.5 → 15.7.6)
- Gallium - CVE-2023-38606 (versions 14.x)
- Parallax - CVE-2023-41974 (versions 16.4 → 16.7)
- terrorbird - CVE-2023-43000 (versions 16.2 → 16.5.1)
- cassowary - CVE-2024-23222 (versions 16.6 → 17.2.1)
- Sparrow - CVE-2024-23225 (versions 17.0 → 17.3)
- Rocket - CVE-2024-23296 (versions 17.1 → 17.4)

"Photon and Gallium are exploiting vulnerabilities that were also used as zero-days as part of Operation Triangulation," Google said. "The Coruna exploit kit also embeds reusable modules to ease the exploitation of the aforementioned vulnerabilities."

In June 2023, the Russian government claimed the campaign was the work of the U.S. National Security Agency, accusing it of hacking "several thousand" Apple devices belonging to domestic subscribers and foreign diplomats as part of a "reconnaissance operation."

UNC6691 has been observed weaponizing the exploit to deliver a stager binary codenamed PlasmaLoader (aka PLASMAGRID) that's designed to decode QR codes from images and run additional modules retrieved from an external server, allowing it to exfiltrate cryptocurrency wallets or sensitive information from various apps like Base, Bitget Wallet, Exodus, and MetaMask, among others.

"The implant contains a list of hard-coded C2s but has a fallback mechanism in case the servers do not respond," GTIG added. "The implant embeds a custom domain generation algorithm (DGA) using the string 'lazarus' as a seed to generate a list of predictable domains. The domains will have 15 characters and use .xyz as a TLD. The attackers use Google's public DNS resolver to validate if the domains are active."

A notable aspect of Coruna is that it skips execution on devices in Lockdown Mode, or if the user is in private browsing. To counter the threat, iPhone users are advised to keep their devices up to date, and enable Lockdown Mode for enhanced security.

The U.S. Cybersecurity and Infrastructure Security Agency (CISA), on March 5, 2026, added CVE-2021-30952, CVE-2023-41974, and CVE-2023-43000 to its Known Exploited Vulnerabilities (KEV) catalog following the abuse of the flaws in the Coruna exploit kit. Federal agencies are advised to apply the necessary fixes by March 26, 2026, for optimal protection.

When reached for comment about the use of Operation Triangulation exploits in Coruna, Kaspersky confirmed that Photon and Gallium target the same vulnerabilities that were used as zero-days in the 2023 campaign.

"These are not trivial bugs – we know that firsthand," Boris Larin, principal security researcher at Kaspersky GReAT, told The Hacker News via email. "CVE-2023-32434 gives an attacker full control over the deepest layer of iOS – the kernel, which governs everything the phone does. CVE-2023-38606 goes a step further: it exploited a previously undocumented feature of Apple's own chips to bypass security protections that operate at the hardware level."

That being said, the Russian cybersecurity vendor noted that both the CVEs have publicly available implementations, meaning any threat actor with sufficient expertise and resources could have come up with their own exploits without relying on Triangulation code. It also pointed out that there is no evidence of actual code reuse to attribute Coruna to the same authors.

"After we discovered and disclosed the Triangulation chain, Apple patched these vulnerabilities and backported fixes as far back as iOS 15.7.x," Larin added. "But many users simply don't update, and Coruna contains 23 exploits across five chains — these two shared CVEs are just the tip of the iceberg."

"This case highlights a fundamental tension: the same closed ecosystem that makes iPhones secure by default also makes it harder for the security industry to provide an additional layer of protection when Apple's own defenses are bypassed. With toolkits like Coruna circulating freely, that's a gap worth addressing."

The statement comes as TechCrunch reported that the exploit kit was likely designed by U.S. military contractor L3Harris, specifically its hacking and surveillance tech division, Trenchant, citing two former employees. Trenchant's hacking tools are sold exclusively to the U.S. government and its allies, including Australia, Canada, New Zealand, and the U.K.

It's currently not known how Coruna ended up with Russian and Chinese hacking groups. But there are some clues as to how this may have happened. Last month, Peter Williams, a former general manager at L3Harris Trenchant, was sentenced to a little over seven years in prison for selling eight zero-day exploits to Russian exploit broker Operation Zero in exchange for millions of dollars.

The exploits could have been "used against any manner of victim, civilian or military around the world, and engage in all manner of crime from cyber fraud, theft, and ransomware, to state-directed spying and offensive cyber operations against military targets," U.S. prosecutors noted.

As TechCrunch stated, it's possible that Operation Zero acquired Coruna and sold it to other threat actors, including financially motivated cybercriminals. Another indicator that points to L3Harris is the use of bird names for the exploits.

"Trenchant/Azimuth do use bird names internally. Their most famous public exploit chain was literally called 'Condor' (a massive bird of prey)," security researcher Costin Raiu said in a post on X last week. "Coruna's heavy bird theme for the early-stage WebContent RCEs and PAC bypasses (cassowary, terrorbird, bluebird, jacurutu, sparrow, plus the lighter breezy/seedbell) fits the same playful naming convention."

In a separate report, c/side shared additional technical details of the distribution mechanism, noting Coruna is delivered as a self-contained HTML file (e.g., group.html or analytics.html) embedded as a hidden <iframe> within a web page. More than 50 delivery domains have been identified.

"The iframe has zero dimensions. It is invisible," Simon Wijckmans said. "It requires no user interaction beyond the page loading. The exploit runs entirely in the browser, in JavaScript, and completes in seconds."

"The delivery pages were hosted on attacker-controlled domains: fake crypto platforms, gambling sites, bingo lures. But the kit does not care where it is hosted. It is a self-contained payload that can be injected anywhere a JavaScript tag can be placed. That means the realistic delivery vectors extend far beyond attacker-owned infrastructure."

The Coruna framework incorporates four layers of obfuscation to bypass static analysis and automated sandboxes, while also skipping execution in scenarios where Apple's Lockdown Mode is detected, or the user is in private browsing mode. The exploit chain goes through six stages -

- Fingerprinting the host to determine if the target is valuable and which exploit chain to use.

- Exploit CVE-2024-23222 to achieve remote code execution
- Bypass Address Space Layout Randomization (ASLR) protections
- Escape the Safari browser sandbox
- Circumvent Pointer Authentication Codes (PAC) on Apple Silicon
- Execute shellcode to drop the final implant (PlasmaLoader aka PLASMAGRID)

"[PLASMAGRID] decodes QR codes from images, fetches additional modules from C2, and exfiltrates cryptocurrency wallet data from MetaMask, Exodus, Bitget Wallet, and Base," Wijckmans said.

(The story was updated after publication to reflect the latest developments and include a response from Kaspersky.)